

Seguridad de la información Clínica Demo

Valentino Farrando · Legajo 31782371
Destinatario: Dirección de la clínica

1. Resumen de situación

Se evaluaron siete riesgos de una clínica ficticia con **120 empleados y 800 pacientes diarios**. El alcance incluye historias clínicas, gestión asistencial, equipos, conectividad, respaldos y datos de obras sociales y facturación.

2 CRÍTICOS	4 ALTOS	1 MEDIO
Continuidad y confidencialidad	Recuperación y operación	Conectividad externa

La valoración utiliza probabilidad e impacto de 1 a 5: su producto determina una puntuación de 1 a 25. Los resultados se basan en supuestos académicos, no en estadísticas de una clínica real. El registro de prueba ID 1001 queda excluido.

2. Cinco riesgos prioritarios

Riesgo	Puntuación	Consecuencia principal
R01 - Ransomware	20 · Crítico	Bloqueo de historias clínicas y atención
R02 - Acceso indebido a facturación	16 · Crítico	Exposición de información restringida
R07 - Respaldos no recuperables	12 · Alto	Pérdida de información y recuperación insuficiente
R04 - Falla del servidor	12 · Alto	Interrupción del sistema clínico
R06 - Acceso desde Wi-Fi de invitados	12 · Alto	Compromiso de recursos internos

Entre los riesgos con puntuación 12 se priorizan recuperación, continuidad asistencial y exposición de la red. **R03 también es alto** y requiere tratamiento; R05 es medio. Umbrales: bajo 1-4, medio 5-9, alto 10-15 y crítico 16-25.

Como analogía solicitada, el **lobo feroz** representa a un atacante externo y **Caperucita Roja**, a una persona expuesta al engaño. La protección debe combinar controles técnicos y procedimientos; no puede depender únicamente de reconocer todos los ataques.

Planes de acción

Tres tratamientos registrados; pendientes de aprobación y ejecución.

PA01 - Protección de equipos y correo

Riesgo: R01 · **Vencimiento:** 30/09/2026 · **Estimación:** USD 8.000

Responsable: Responsable de Sistemas · **Estado:** Planificado

Acciones. Inventariar equipos, centralizar su protección y actualizaciones, configurar filtros de correo y capacitar al personal. Se suponen 60 computadoras, sin equiparar empleados con equipos.

Finalización. Cobertura del alcance verificada, excepciones documentadas y pruebas controladas de detección, aislamiento y correo.

Primer año: licencias USD 4.500; configuración USD 2.000; capacitación y pruebas USD 1.500.

PA02 - Control de acceso a facturación

Riesgo: R02 · **Vencimiento:** 23/09/2026 · **Estimación:** USD 1.200

Responsable: Responsable de Sistemas · **Estado:** Planificado

Acciones. Inventariar accesos, aprobar una matriz de permisos por función, retirar permisos innecesarios y establecer revisiones periódicas. Administración valida los accesos.

Finalización. Matriz aprobada, permisos aplicados y pruebas documentadas de accesos permitidos y denegados.

30 horas de trabajo a USD 40 por hora; sin nuevas licencias previstas.

PA03 - Respaldos recuperables

Riesgo: R07 · **Vencimiento:** 30/09/2026 · **Estimación:** USD 3.000

Responsable: Responsable de Sistemas · **Estado:** Planificado

Acciones. Definir alcance y objetivos de recuperación, disponer de copias separadas y aisladas, monitorear respaldos y probar restauraciones en un entorno independiente.

Finalización. Restauración validada por las áreas usuarias, tiempos registrados y calendario de pruebas establecido.

Primer año: almacenamiento y copia externa USD 1.500; configuración, pruebas y documentación USD 1.500.

Inversión total propuesta: USD 12.200

Los importes son simulados, requieren validación de alcance y no constituyen cotizaciones ni presupuesto aprobado. PA03 complementa la recuperación de R01; no reemplaza su prevención.

Decisiones y seguimiento

3. Decisiones solicitadas a Dirección

- Validar alcance, responsables, fechas y presupuestos de los tres planes.
- Priorizar conjuntamente prevención del ransomware, control de accesos y recuperación de información.
- Definir con las áreas usuarias el tiempo tolerable sin servicio y la pérdida de datos admisible.
- Programar planes detallados para R03, R04, R05 y R06. Su ausencia actual no representa aceptación del riesgo.

4. Recomendaciones prioritarias

- Aplicar mínimo privilegio y revisar accesos ante bajas o cambios de función.
- Separar la red de invitados de los recursos internos.
- Probar la restauración: una copia existente no garantiza recuperación. Mantener procedimientos de continuidad asistencial y administrativa.
- **No ubicar centros de datos ni servidores junto a cocinas o debajo de piletas**, para reducir exposición a incendios, fugas e inundaciones. Es una recomendación preventiva, no un hallazgo sobre la instalación.

La analogía de los **tres cerditos** ilustra la necesidad de defensas resistentes. Prevención, detección, respuesta y recuperación deben funcionar como capas complementarias.

5. Riesgo restante y control de avance

Se propone seguimiento semanal de tareas, responsables, desvíos, costos y evidencias. **Las puntuaciones actuales no se reducen:** Mitigation Percent permanece en 0. La eficacia debe verificarse antes de recalcular el riesgo residual.

Dirección Médica conserva la responsabilidad sobre R01 y R04; Administración, sobre R02, R03 y R05; Sistemas, sobre R06 y R07. La ejecución técnica de los tres planes corresponde a Sistemas.

El informe técnico desarrolla la comparación con NIST SP 800-30 y la propuesta de vinculación con GitHub Issues. La integración no fue implementada.

Conclusión

La prioridad es proteger la atención y la información mediante acciones verificables. Aprobar y ejecutar los tres planes constituye el siguiente paso: su registro en SimpleRisk acredita planificación, no reducción efectiva del riesgo.